Reporte técnico

Mi primer laboratorio seguro

Denise Romero | Curso: Ciberseguridad, Coderhouse

Introducción: de qué se trata

En este reporte documento la construcción de un laboratorio de pruebas aislado y endurecido (hardening), armado con VirtualBox sobre un Mac con procesador Intel. El sistema instalado es Ubuntu Server 24.04 LTS. El objetivo es contar con un entorno seguro, recuperable y listo para prácticas futuras, como el análisis de tráfico de red en el próximo módulo.

En el trabajo anterior armé un inventario de mis activos digitales (correo electrónico, cuentas bancarias y nube de fotos) y analicé cada uno según la **tríada CIA**: **Confidencialidad** (que solo acceda quien está autorizado), **Integridad** (que nadie modifique la información o el sistema sin permiso) y **Disponibilidad** (poder usarlo cuando lo necesito). En este laboratorio aplico el mismo análisis, pero ahora el activo a proteger es la máquina virtual. Por eso cada paso incluye una captura como evidencia, la justificación técnica y qué pilar de la tríada protege.

El activo de este laboratorio

Siguiendo el formato del inventario de activos, primero analizo qué hay que proteger de la VM y por qué. Esta tabla funciona como punto de partida: los cinco pasos que siguen son los controles que responden a la vulnerabilidad y a la amenaza detectadas.

ACTIVO: Máquina virtual del laboratorio (Ubuntu Server 24.04 LTS). Es importante protegerla porque es el entorno donde voy a practicar, y en el próximo módulo va a guardar capturas de tráfico de red que pueden contener información sensible.

Confidencialidad	Es importante protegerla para que ningún equipo de mi red ni de internet pueda conectarse a la VM, y para que cada usuario solo pueda ver sus propios archivos.
Integridad	Es importante protegerla para que nadie, ni un atacante ni un error mío en una prueba, modifique la configuración del sistema o instale software sin autorización.
Disponibilidad	Es importante protegerla para poder usar el laboratorio cuando lo necesite y volver a un estado funcional si una práctica rompe el sistema.
Vulnerabilidad	Una instalación recién hecha tiene paquetes sin parchear, una sola cuenta con permisos de administrador para todo y ningún punto de restauración.
Amenaza externa	Un atacante podría aprovechar una vulnerabilidad conocida de un paquete desactualizado, o un archivo malicioso descargado durante una práctica podría tomar el control de la cuenta que estoy usando.

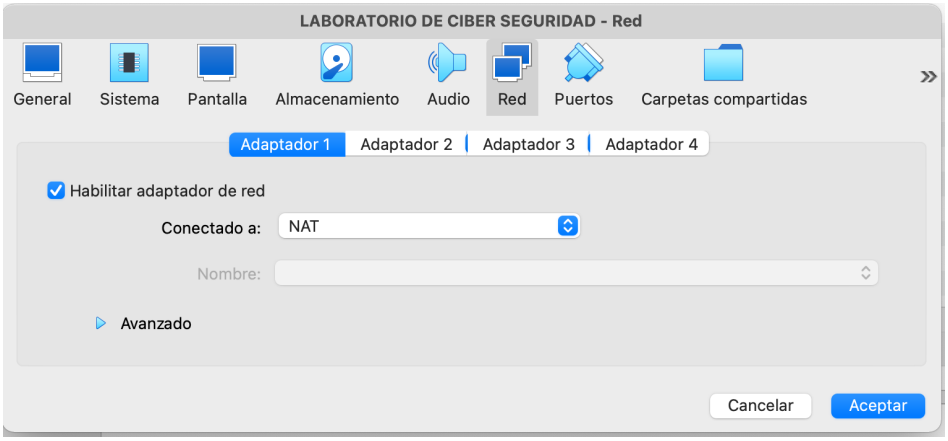
Paso 1: La fundación, red en modo NAT

Qué hice: Antes de encender la máquina virtual, configuré el Adaptador 1 en modo NAT desde Configuración > Red.

Justificación: NAT permite que la VM salga a internet, por ejemplo para descargar actualizaciones, pero la oculta detrás de VirtualBox: ningún equipo externo puede iniciar una conexión hacia ella. Esto segmenta el laboratorio, reduce la superficie de ataque y limita el impacto que las pruebas puedan tener sobre los demás dispositivos de mi red.

Cómo protege a mi máquina real (host): la VM queda en una red virtual propia (10.0.2.0/24), separada de la red de mi Mac y de mi Wi-Fi. Si en una práctica la VM se infecta, el problema queda contenido en el laboratorio y no aparece como un equipo más de mi red. Descarté el modo Bridge (puente) justamente por eso: en Bridge la VM sería un dispositivo visible en la red de mi casa, expuesto a los otros equipos y capaz de llegar a ellos directamente.

> **Relación con la tríada CIA: Confidencialidad.** Es el pilar principal de este paso. Si nadie de afuera puede iniciar conexiones hacia la VM, tampoco puede llegar a lo que guarda adentro. Responde directamente a la amenaza externa de la tabla del activo: la primera barrera es que el atacante no pueda alcanzar el equipo.



Captura 1. Adaptador 1 habilitado y conectado a NAT.

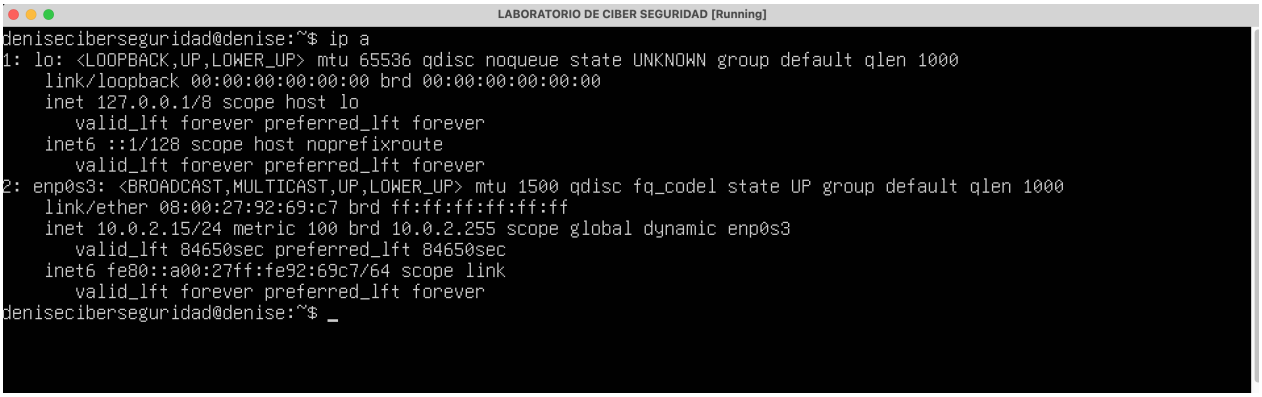
Paso 2: Instalación del sistema y configuración de red

Qué hice: Instalé Ubuntu Server 24.04 LTS en la VM y ejecuté el comando `ip a` para verificar la configuración de red.

Resultado: La interfaz `enp0s3` está activa (estado UP) y recibió la dirección `10.0.2.15/24`, que es el rango que VirtualBox asigna en modo NAT. Esto confirma que el aislamiento del paso anterior está aplicado.

Justificación: Elegí Ubuntu Server, una instalación sin entorno gráfico, porque cada programa instalado es un posible punto de entrada: menos software significa menos vulnerabilidades que mantener. Verificar la red con `ip a` deja evidencia de que la VM funciona detrás de NAT.

> **Relación con la tríada CIA: Confidencialidad e Integridad.** Un sistema mínimo tiene menos fallas que un atacante pueda usar para leer datos (confidencialidad) o para modificar el sistema (integridad). Además, la verificación con ip a cumple un rol propio: no alcanza con configurar un control, hay que comprobar que realmente quedó aplicado.



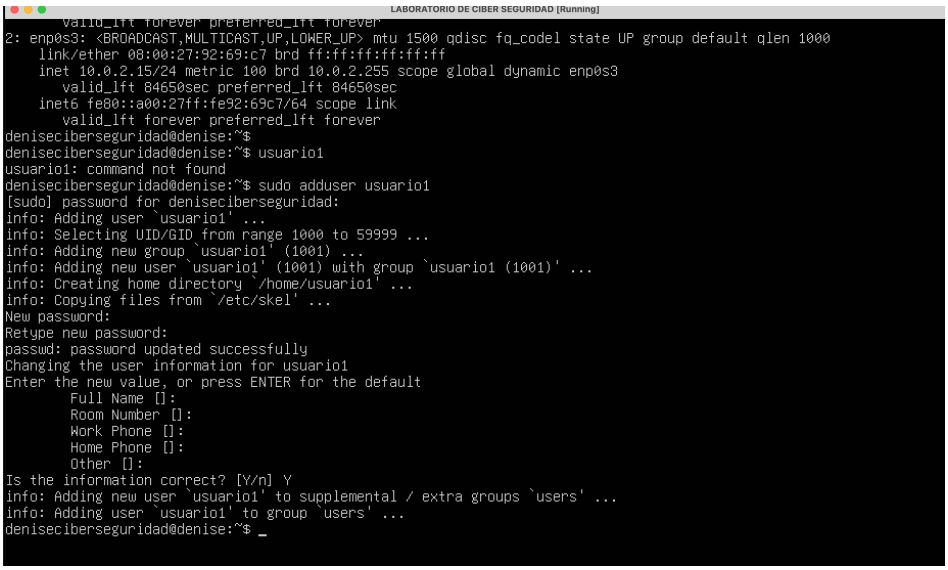
Captura 2. Resultado de `ip a`*: interfaz enp0s3 con IP 10.0.2.15/24.*

Paso 3: Identidades y privilegios, usuario con permisos limitados

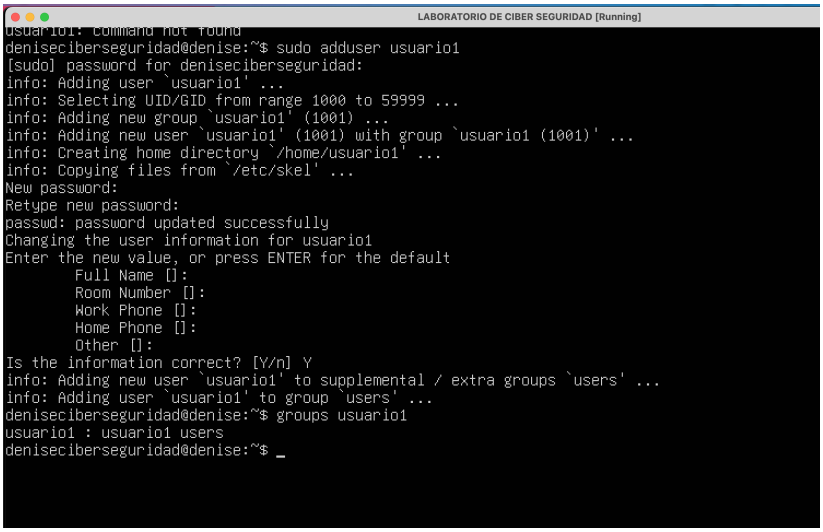
Qué hice: Creé un usuario estándar, `usuario1`, con `sudo adduser usuario1`. Con `groups usuario1` comprobé que pertenece solo a los grupos `usuario1` y `users`, y que **no** pertenece al grupo `sudo`. Por último listé los directorios personales con `ls /home`, donde aparecen los dos usuarios del sistema.

Justificación: Apliqué el principio de mínimo privilegio: cada cuenta tiene solo los permisos que necesita. Si la cuenta de uso diario se ve comprometida, el atacante no puede instalar software ni modificar la configuración del sistema. La cuenta administradora queda reservada para tareas de mantenimiento.

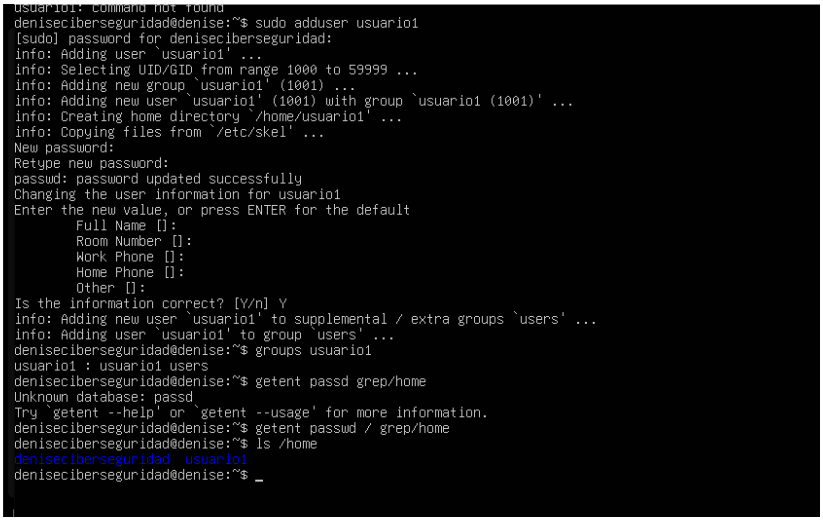
> **Relación con la tríada CIA: Integridad (principal) y Confidencialidad.** Sin sudo, usuario1 no puede cambiar archivos del sistema, así que un malware que tome esa cuenta queda limitado a ella: eso protege la integridad. También protege la confidencialidad, porque un usuario sin privilegios no puede leer archivos protegidos del sistema ni los de otros usuarios. Este paso responde a la vulnerabilidad de “una sola cuenta con permisos para todo”.



Captura 3a. Creación del usuario estándar con `adduser`*.*



Captura 3b. `groups usuario1`*: el usuario no pertenece al grupo sudo.*



Captura 3c. Lista de usuarios del sistema (`ls /home`*): deniseciberseguridad y usuario1.*

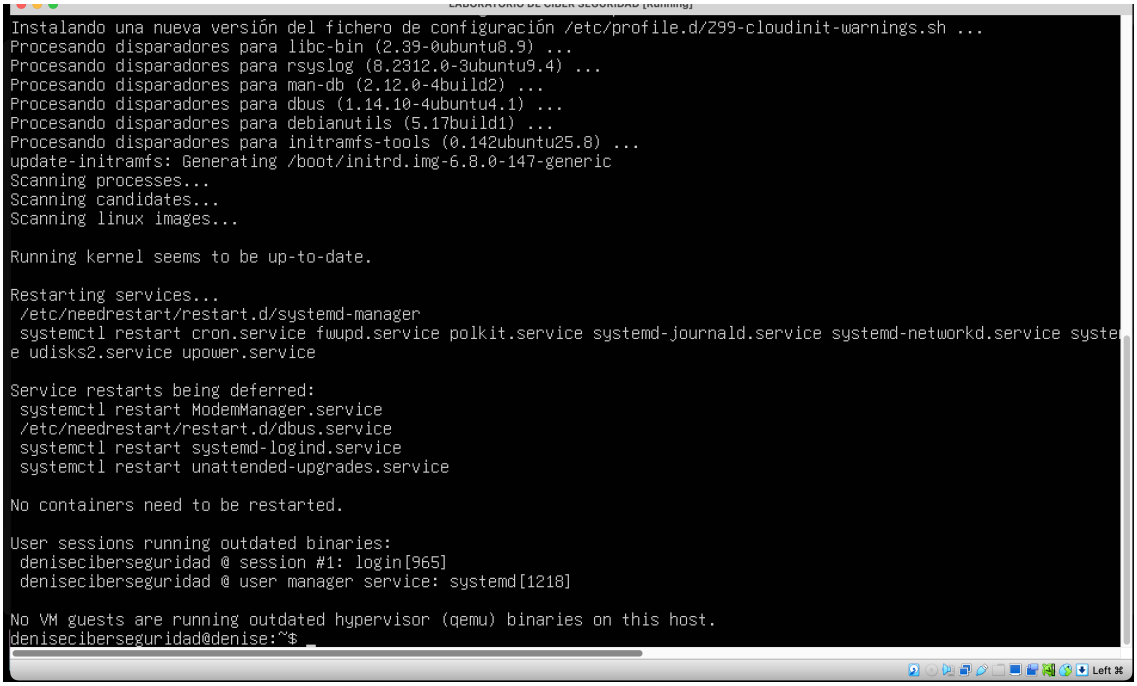
Paso 4: Mantenimiento y parches, sistema al día

Qué hice: Ejecuté `sudo apt update` y `sudo apt upgrade -y` para aplicar las actualizaciones pendientes, reinicié la VM y volví a verificar que no quedaran paquetes por actualizar. También revisé los permisos con `ls -l /home`.

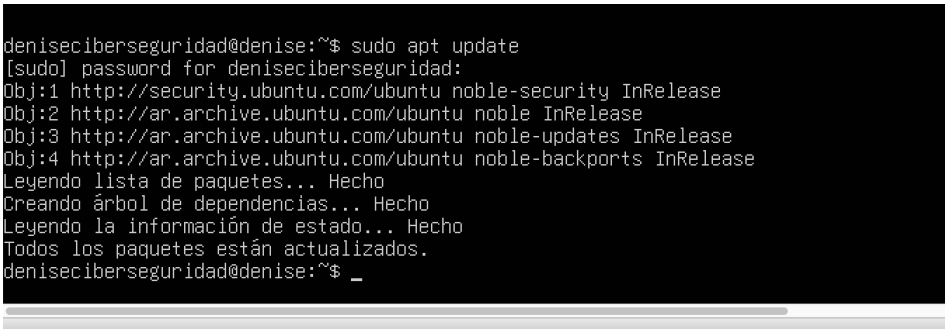
Resultado: El sistema informa que todos los paquetes están actualizados. Los directorios personales tienen permisos `drwxr-x---`: cada carpeta pertenece a su usuario y el resto de los usuarios no tiene acceso.

Justificación: Las actualizaciones corrigen vulnerabilidades conocidas, y un sistema sin parches es uno de los objetivos más fáciles para un atacante, porque las fallas ya son públicas. Revisar los permisos confirma que cada usuario accede solo a sus propios archivos.

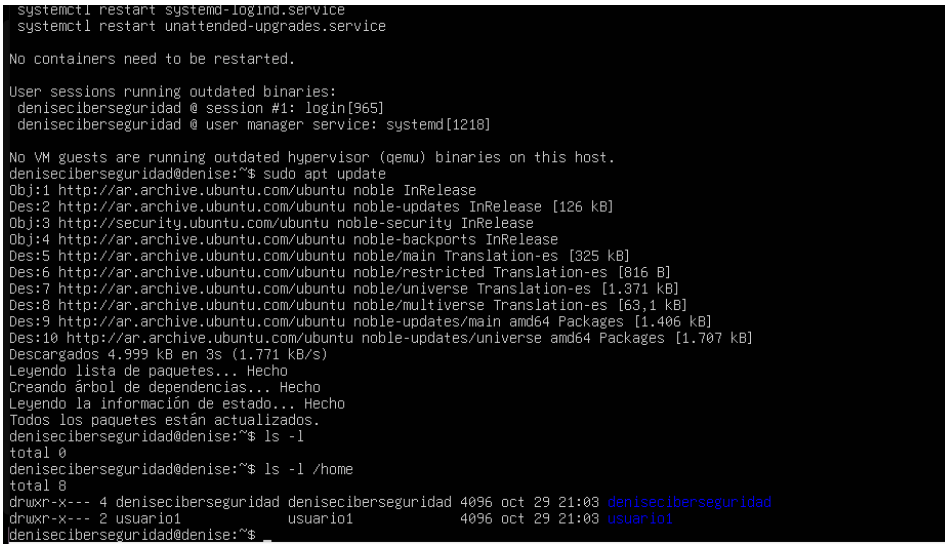
> **Relación con la tríada CIA: los tres pilares.** Los parches cierran fallas que permitirían modificar el sistema (integridad) o dejarlo fuera de servicio (disponibilidad), y muchas también evitan fugas de información. Los permisos drwxr-x--- protegen la confidencialidad: usuario1 no puede entrar a la carpeta del administrador ni al revés. Este paso responde a la vulnerabilidad de “paquetes sin parchear”.



Captura 4a. Instalación de las actualizaciones con `apt upgrade`*: el kernel en ejecución está al día.*



Captura 4b. `sudo apt update` *tras el reinicio: «Todos los paquetes están actualizados».*



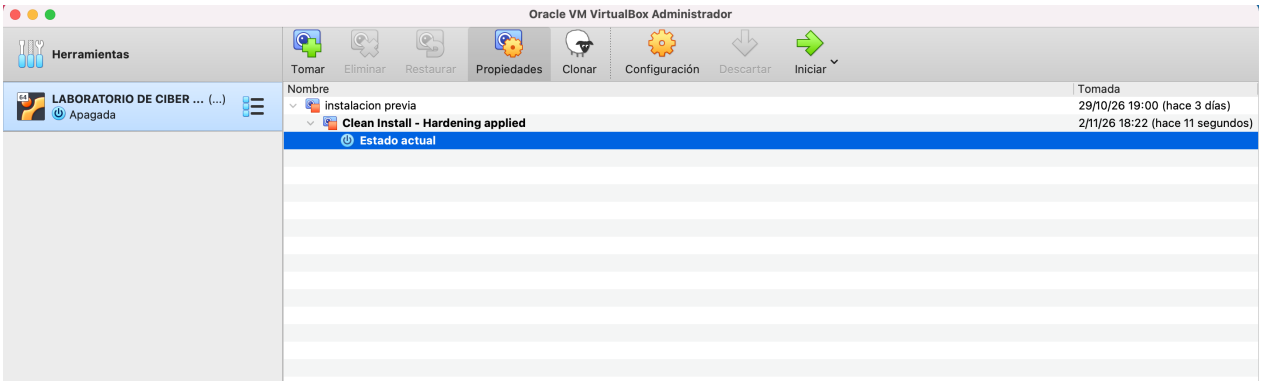
Captura 4c. Permisos de los directorios personales con `ls -l /home`*.*

Paso 5: La red de seguridad, snapshot de resiliencia

Qué hice: Apagué la máquina virtual y creé una instantánea llamada **Clean Install - Hardening applied**, que guarda el estado del sistema con la red en NAT, el usuario estándar creado y las actualizaciones aplicadas. Es mi "máquina del tiempo" por si algo sale mal en el futuro. La instantánea "instalacion previa" que aparece arriba es un punto de restauración anterior al hardening completo.

Justificación: El snapshot permite volver a un estado limpio y seguro en segundos. Esto es clave en un laboratorio, donde voy a hacer pruebas que pueden romper o comprometer el sistema. Lo tomé con la VM apagada para que el disco quede en un estado consistente, sin procesos escribiendo a mitad de camino.

> **Relación con la tríada CIA: Disponibilidad (principal) e Integridad.** Si una práctica rompe el sistema, puedo volver a usarlo enseguida: eso es disponibilidad. Y como la instantánea guarda un estado que ya verifiqué en los pasos 1 a 4, restaurarla me devuelve a una configuración confiable, sin cambios hechos por un malware o por un error: eso es integridad. Responde a la vulnerabilidad de "ningún punto de restauración".



Captura 5. Administrador de instantáneas de VirtualBox: Clean Install - Hardening applied, con la VM apagada.

Conexión con el inventario de activos

Las vulnerabilidades que encontré en mis activos personales tienen su equivalente en el laboratorio. Esto muestra que los controles son los mismos, aunque cambie la herramienta:

Activo del TP anterior	Vulnerabilidad detectada	Control equivalente en el laboratorio
Correo electrónico	Hace tiempo que no actualizo la contraseña.	Paso 4: mantener el sistema actualizado. En los dos casos, lo que se deja sin renovar se vuelve el punto débil.
Nube de fotos	Álbumes compartidos sin revisar quién tiene acceso.	Pasos 3 y 4: revisar grupos con `groups` y permisos con `ls -l` para saber exactamente quién accede a qué.
Cuentas bancarias	Datos de la tarjeta cargados en varias aplicaciones.	Pasos 2 y 3: reducir el software instalado y los permisos. Cuantos menos lugares tienen acceso, menos puntos de exposición.
Nube de fotos y correo	Necesito acceder aunque pierda el teléfono o tenga que recuperar una cuenta.	Paso 5: el snapshot cumple el mismo rol que un respaldo, garantiza la disponibilidad.

Resumen de evidencias

Como el laboratorio usa Ubuntu Server, las capas de identidades y de mantenimiento están documentadas en su equivalente Linux (usuario estándar con adduser y actualizaciones con apt).

Criterio de la rúbrica	Evidencia en este laboratorio	Pilar CIA	Capturas
Red y segmentación	VM aislada en modo NAT, IP 10.0.2.15/24	Confidencialidad	1, 2
Identidades y privilegios	Usuario estándar usuario1, sin pertenecer al grupo sudo	Integridad y Confidencialidad	3a, 3b, 3c
Mantenimiento y parches	apt update y apt upgrade, sistema al día y permisos revisados	Integridad, Disponibilidad y Confidencialidad	4a, 4b, 4c
Resiliencia con snapshots	Instantánea Clean Install - Hardening applied con la VM apagada	Disponibilidad e Integridad	5
Calidad del reporte	Estructura por pasos, con evidencia, justificación y pilar CIA en cada uno	Los tres	Todo el documento

Conclusión

Construí un laboratorio aislado en NAT, con un usuario sin privilegios de administrador, el sistema actualizado y un punto de restauración. Con estos cinco pasos quedan cubiertos los tres pilares de la tríada: la red en NAT y los permisos protegen la **confidencialidad**, el mínimo privilegio y los parches protegen la **integridad**, y el snapshot asegura la **disponibilidad**. Aprendí que el hardening no depende de herramientas complejas, sino de decisiones simples y bien justificadas: aislar, limitar privilegios, parchear y poder recuperar.

También identifiqué límites de lo que hice, que me sirven como mejoras futuras. NAT bloquea las conexiones que llegan desde afuera, pero no las que salen de la VM, así que un firewall como UFW reforzaría la confidencialidad. El snapshot se guarda en el mismo disco del Mac, por lo que no reemplaza un respaldo externo; exportar la VM a otro medio reforzaría la disponibilidad. Y como las actualizaciones siguen saliendo, después de restaurar la instantánea conviene volver a ejecutar apt update para no perder integridad. En el próximo módulo voy a usar este mismo laboratorio para capturar y analizar tráfico de red con Wireshark.